**MF0487_3 · AUDITORÍA DE SEGURIDAD INFORMÁTICA**

# LABORATORIO 3

## Análisis de Protocolos de Red con Wireshark

**Objetivo: Metasploitable 2 · Tráfico generado desde Kali Linux Purple**

Entorno: 2 máquinas — Kali Linux Purple + Metasploitable 2

Herramientas: Wireshark · tcpdump · tshark

Normativa: ENS (mp.com.2, mp.com.3) · ISO 27001:2022 A.8.20, A.8.24 · MAGERIT v3 · RGPD art. 32

Duración estimada: 4 horas · Nivel: Intermedio · Prerrequisitos: LAB-01, LAB-02

**⚠ Este documento es de uso exclusivo en entornos de laboratorio controlado.**

# 0. FICHA TÉCNICA DEL LABORATORIO

| | | | |
|---|---|---|---|
| **Código** | LAB-03 | **UDs** | UD4, UD5, UD6 |
| **Título** | Análisis de Protocolos de Red con Wireshark | **Duración** | 4 h |
| **Normativa** | MAGERIT v3 · ENS (mp.com.2, mp.com.3) · ISO 27001:2022 A.8.20, A.8.24 · RGPD art. 32 | **Nivel** | Intermedio |
| **Herramientas** | Wireshark · tcpdump · tshark · Nmap (generación de tráfico) | **Prerrequisito** | LAB-01, LAB-02 |
| **Máquinas** | *Kali Linux Purple (captura y análisis) \| Metasploitable 2 (generador de tráfico objetivo)* | | |
| **Objetivo** | *Capturar y analizar el tráfico de red generado entre Kali y Metasploitable 2. Identificar protocolos inseguros, credenciales en texto claro, patrones de ataque y evidencias forenses de red. Relacionar los hallazgos con los controles de seguridad de las comunicaciones del ENS e ISO 27001:2022.* | | |

# 1. MARCO NORMATIVO — SEGURIDAD DE LAS COMUNICACIONES

El análisis de protocolos de red es la herramienta técnica que permite verificar si los controles de seguridad de las comunicaciones están correctamente implementados. Las siguientes referencias normativas fundamentan este laboratorio:

## 1.1 ENS — Esquema Nacional de Seguridad (RD 311/2022)

- mp.com.2 — Cifrado de las comunicaciones: en sistemas de categoría MEDIA y ALTA, las comunicaciones que transporten datos de carácter personal o sensibles deben estar cifradas. El protocolo Telnet, FTP y otros en texto claro incumplen directamente este control.
- mp.com.3 — Autenticidad y confidencialidad de las comunicaciones: las entidades que se comunican deben autenticarse mutuamente y la información transmitida debe ser confidencial. Los protocolos sin cifrado ni autenticación fuerte (Telnet, rlogin, FTP) incumplen ambos requisitos.
- op.mon.1 — Detección de intrusiones: los sistemas de monitorización de red (IDS/IPS) y el análisis de capturas de tráfico son las herramientas técnicas de cumplimiento de esta medida.

## 1.2 ISO 27001:2022

- A.8.20 — Seguridad de las redes: 'Las redes deberán gestionarse y controlarse para proteger la información en los sistemas y aplicaciones.' El análisis de protocolos permite verificar la configuración real de la red frente a la documentada.
- A.8.21 — Seguridad de los servicios de red: exige la identificación e inclusión de todos los mecanismos de seguridad de los servicios de red en los acuerdos con proveedores.
- A.8.24 — Uso de criptografía: exige el uso de criptografía para proteger la confidencialidad, autenticidad e integridad de la información. La captura de credenciales en texto claro es evidencia directa de incumplimiento de este control.

## 1.3 RGPD — Reglamento (UE) 2016/679

- Art. 32.1.a: la seudonimización y el cifrado de datos personales son medidas técnicas de seguridad del tratamiento. La transmisión de datos personales sin cifrar a través de la red (por ejemplo, credenciales de acceso a bases de datos con datos personales) constituye una violación del principio de integridad y confidencialidad (art. 5.1.f).

## 1.4 MAGERIT v3 — Amenazas relevantes

| Código | Amenaza MAGERIT v3 | Técnica de análisis de red asociada |
|---|---|---|
| [A.5] | Suplantación de identidad del usuario | Captura de credenciales en texto claro (Telnet, FTP, HTTP Basic Auth) |
| [A.9] | Re-encaminamiento de mensajes | Análisis de tráfico ARP, detección de ARP spoofing |
| [A.10] | Alteración de secuencia | Análisis de flags TCP, detección de sesiones manipuladas |
| [A.11] | Acceso no autorizado | Identificación de conexiones a servicios sin autenticación fuerte |
| [E.2] | Errores del administrador | Protocolos de gestión inseguros: Telnet, rlogin, rsh, SNMPv1/v2 |
| [E.9] | Errores de reencaminamiento | Tablas ARP anómalas, entradas duplicadas |

## 1.5 Evidencia forense de red — valor probatorio

Las capturas de tráfico (.pcap) son evidencias digitales con valor forense. Para que sean admisibles en un procedimiento de auditoría o legal, deben cumplir:

- Cadena de custodia documentada: quién capturó el tráfico, en qué máquina, en qué momento y mediante qué herramienta.

- Integridad verificable: el fichero .pcap debe tener un hash SHA-256 calculado en el momento de la captura y verificable posteriormente.
- Mínima intervención: la captura no debe modificar el tráfico, solo observarlo (modo promiscuo o span port).
- Referencia normativa: la Ley de Enjuiciamiento Criminal (arts. 326-334) regula la validez de la prueba digital en España. En el contexto de auditoría interna, la CCN-STIC 817 establece los requisitos de documentación de evidencias.

# 2. ENTORNO DE LABORATORIO

## 2.1 Topología

| Máquina | Rol en este laboratorio | IP |
|---|---|---|
| Kali Linux Purple | Captura y análisis de tráfico. Generación de tráfico de prueba hacia Metasploitable 2. | Anotar: _____ |
| Metasploitable 2 | Objetivo. Proporciona los servicios inseguros que generan el tráfico analizado. | Anotar: _____ |

## 2.2 Herramientas disponibles en Kali Linux Purple

Todas las herramientas necesarias están incluidas en Kali Linux Purple por defecto:

| Herramienta | Versión mínima | Función en el laboratorio | Verificación |
|---|---|---|---|
| Wireshark | ≥ 4.0 | Captura y análisis gráfico de paquetes | wireshark --version |
| tcpdump | ≥ 4.99 | Captura en línea de comandos, generación de .pcap | tcpdump --version |
| tshark | ≥ 4.0 | Análisis de .pcap desde terminal (automatizable) | tshark --version |
| Nmap | ≥ 7.90 | Generación de tráfico controlado hacia Metasploitable 2 | nmap --version |

## 2.3 Preparación del entorno

Ejecuta desde Kali antes de comenzar las tareas:

```
# Comprobar conectividad
ping -c 3 <IP_META>

# Identificar la interfaz de red activa
ip addr show | grep -E 'inet |^[0-9]'
# Anota el nombre de la interfaz (eth0, ens33, enp0s3...): __________

# Crear directorio de trabajo del laboratorio
mkdir -p ~/lab03

# Verificar Wireshark
wireshark --version | head -1
```

ℹ A lo largo del laboratorio se usa <IP_META> para referirse a la IP de Metasploitable 2 e <IFACE> para la interfaz de red de Kali. Sustitúyelos por los valores reales de tu entorno antes de ejecutar cada comando.

# 3. OBJETIVOS DE APRENDIZAJE

- Comprender la arquitectura de captura de tráfico en Wireshark: interfaces, filtros de captura BPF y filtros de visualización.
- Capturar tráfico de red en tiempo real generado entre Kali y Metasploitable 2.
- Aplicar filtros de visualización Wireshark para aislar protocolos específicos: Telnet, FTP, HTTP, SMB, ARP, ICMP.
- Reconstruir sesiones completas usando Follow TCP/UDP Stream e identificar credenciales transmitidas en texto claro.
- Usar tshark en línea de comandos para extracción automatizada de artefactos de red.
- Analizar tráfico ARP e identificar comportamientos anómalos relacionados con amenazas MAGERIT [A.9] y [E.9].
- Documentar cada hallazgo con su filtro Wireshark, captura de pantalla y referencia al control ENS / ISO 27001 incumplido.
- Calcular el hash SHA-256 de los ficheros .pcap para garantizar la integridad de las evidencias forenses.

# 4. DESARROLLO DEL LABORATORIO

## TAREA 1 — Configuración de Wireshark y primera captura (20 min)

### 1.1 Interfaz de Wireshark

Abre Wireshark con privilegios suficientes para capturar en la interfaz de red:

```
sudo wireshark &
```

En la pantalla de inicio verás la lista de interfaces disponibles con un gráfico de actividad. Identifica la interfaz que conecta con Metasploitable 2 (la que muestra actividad cuando haces ping).

### 1.2 Filtro de captura BPF — limitar el tráfico capturado

Un filtro de captura BPF (Berkeley Packet Filter) se aplica ANTES de capturar, reduciendo el volumen de datos almacenado. Se configura en el campo 'Capture filter' antes de hacer clic en Start:

| Filtro BPF | Propósito | Cuándo usarlo |
|---|---|---|
| host <IP_META> | Solo tráfico hacia/desde Metasploitable 2 | Inicio del laboratorio — filtro general |
| host <IP_META> and port 23 | Solo tráfico Telnet con el objetivo | Tarea 2 — análisis Telnet |
| host <IP_META> and port 21 | Solo tráfico FTP con el objetivo | Tarea 3 — análisis FTP |
| host <IP_META> and port 80 | Solo tráfico HTTP con el objetivo | Tarea 3 — análisis HTTP |
| arp | Solo tráfico ARP de la red | Tarea 5 — análisis ARP |

### 1.3 Primera captura general

Inicia una captura general de todo el tráfico con Metasploitable 2:

1. En Wireshark, selecciona la interfaz de red activa (<IFACE>).
2. En el campo Capture filter introduce: host <IP_META>
3. Haz clic en el botón azul ▶ (Start capturing packets).
4. Desde otro terminal, genera tráfico básico:

```
ping -c 10 <IP_META>
nmap -sV --top-ports 20 <IP_META>
```

5. Vuelve a Wireshark y detén la captura con el botón rojo ■ (Stop).
6. Guarda la captura: File → Save As → ~/lab03/captura_general.pcap

### 1.4 Calcular el hash de integridad del fichero .pcap

Inmediatamente tras guardar cada captura, calcula su hash SHA-256. Este valor acredita la integridad de la evidencia forense:

```
sha256sum ~/lab03/captura_general.pcap | tee ~/lab03/captura_general.pcap.sha256
```

| Fichero .pcap | Hash SHA-256 (rellenar) | Fecha y hora de captura |
|---|---|---|
| captura_general.pcap | _____ | _____ |
| captura_telnet.pcap | _____ | _____ |

| | | |
|---|---|---|
| captura_ftp.pcap | _____ | _____ |
| captura_http.pcap | _____ | _____ |
| captura_arp.pcap | _____ | _____ |
| captura_smb.pcap | _____ | _____ |

✓ **TIP:** Acostúmbrate a calcular el hash SHA-256 de cada evidencia inmediatamente después de capturarla. En una auditoría forense real, este hash es el que certifica que el fichero no ha sido alterado desde el momento de la captura. Sin él, la evidencia puede ser cuestionada.

# TAREA 2 — Captura y análisis de Telnet: credenciales en texto claro (45 min)

Telnet es uno de los protocolos de mayor riesgo por transmitir toda la sesión, incluidas las credenciales, sin ningún tipo de cifrado. Este análisis proporciona evidencia directa del incumplimiento del control ENS mp.com.2.

## 2.1 Captura dirigida — solo tráfico Telnet

Abre una captura nueva en Wireshark con filtro BPF específico:

7. Detén cualquier captura activa.
8. Selecciona de nuevo la interfaz <IFACE>.
9. Filtro de captura BPF: host <IP_META> and port 23
10. Haz clic en ▶ para iniciar la captura.
11. Desde otro terminal, inicia una sesión Telnet hacia Metasploitable 2:

```
telnet <IP_META>
# Usuario: msfadmin
# Contraseña: msfadmin
# Ejecuta estos comandos en la sesión Telnet remota:
# whoami
# uname -a
# cat /etc/passwd | head -5
# exit
```

12. Detén la captura en Wireshark y guarda como: ~/lab03/captura_telnet.pcap

```
sha256sum ~/lab03/captura_telnet.pcap | tee ~/lab03/captura_telnet.pcap.sha256
```

## 2.2 Filtros de visualización Wireshark — análisis Telnet

Con la captura cargada, aplica los siguientes filtros en la barra de filtros de Wireshark (NO en el filtro de captura):

**Filtro 1 — Ver solo paquetes Telnet:**

```
telnet
```

**Filtro 2 — Ver el intercambio de datos de la sesión:**

```
tcp.port == 23
```

**Filtro 3 — Ver paquetes que contienen texto (datos de aplicación):**

```
tcp.port == 23 and tcp.len > 0
```

## 2.3 Reconstrucción de la sesión completa — Follow TCP Stream

Follow TCP Stream es la función más potente de Wireshark para reconstruir sesiones: reensambla todos los paquetes de una conexión TCP y muestra el contenido en orden, tal y como lo vio la aplicación.

13. En la lista de paquetes, haz clic derecho sobre cualquier paquete Telnet.
14. Selecciona: Follow → TCP Stream
15. Se abrirá una ventana mostrando toda la sesión. El texto en ROJO es el tráfico enviado por Kali, el AZUL es la respuesta de Metasploitable 2.
16. Localiza las credenciales de acceso (usuario y contraseña). Aparecerán en texto claro.
17. Toma una captura de pantalla de la ventana Follow TCP Stream con las credenciales visibles.
18. Guarda el contenido: botón Save As → ~/lab03/sesion_telnet_completa.txt

> ⚠ **AVISO:** La ventana de Follow TCP Stream muestra literalmente lo que un atacante con acceso a la red vería al interceptar la sesión Telnet. Esta evidencia demuestra directamente el riesgo de la amenaza MAGERIT [A.5] (Suplantación de identidad) y el incumplimiento del control ENS mp.com.2.

## 2.4 Extracción con tshark desde línea de comandos

tshark permite automatizar el análisis de capturas, útil para incluir resultados en informes o procesar múltiples ficheros:

```
# Extraer todo el contenido de las sesiones Telnet
tshark -r ~/lab03/captura_telnet.pcap -Y 'telnet' -T fields -e telnet.data
2>/dev/null | strings


# Ver el flujo TCP completo en texto
tshark -r ~/lab03/captura_telnet.pcap -q -z follow,tcp,ascii,0 2>/dev/null | head -
60
```

## 2.5 Registro del hallazgo P-01

| P-01 Telnet (puerto 23) — Riesgo ALTO — CWE-319 | |
|---|---|
| **Descripción del riesgo** | El protocolo Telnet transmite toda la sesión (credenciales, comandos, respuestas) en texto claro sin ningún cifrado. Cualquier agente con acceso pasivo a la red puede capturar e interpretar el contenido íntegro de la sesión. |
| **Filtro Wireshark** | tcp.port == 23 / Follow → TCP Stream para reconstruir sesión completa |
| **Qué buscar / evidencia** | Credenciales de usuario (login y password) visibles en texto claro en el TCP Stream. Comandos ejecutados remotamente accesibles. Contenido de ficheros leídos durante la sesión (/etc/passwd, etc.). |
| **Control ENS / ISO 27001** | ENS: mp.com.2 (Cifrado obligatorio — nivel MEDIA/ALTA). mp.com.3 (Autenticidad y confidencialidad). ISO 27001:2022 A.8.24 (Criptografía). MAGERIT: Amenaza [A.5] dimensión C. |
| **Recomendación** | Deshabilitar el servicio Telnet: systemctl disable telnet --now. Migrar toda la gestión remota a SSH (OpenSSH, cifrado AES-256). Implementar política de prohibición de protocolos legacy en texto claro. |

# TAREA 3 — Análisis de FTP: comandos y transferencia de ficheros en claro (45 min)

FTP usa dos canales TCP separados: el canal de control (puerto 21, credenciales y comandos) y el canal de datos (puerto 20 o pasivo, transferencia de ficheros). Ambos viajan en texto claro.

## 3.1 Captura de sesión FTP

19. Inicia una nueva captura en Wireshark con filtro BPF: host <IP_META> and port 21 or port 20
20. Desde terminal, conecta por FTP anónimo:

```
ftp <IP_META>
# Name: anonymous
# Password: lab03@test.com
# ftp> ls -la
# ftp> pwd
# ftp> get <nombre_fichero_visible>   (si hay alguno accesible)
# ftp> quit
```

21. Conecta también con credenciales reales para ver el flujo de autenticación:

```
ftp <IP_META>
# Name: msfadmin
# Password: msfadmin
# ftp> ls
# ftp> quit
```

22. Detén la captura y guarda como: ~/lab03/captura_ftp.pcap

```
sha256sum ~/lab03/captura_ftp.pcap | tee ~/lab03/captura_ftp.pcap.sha256
```

## 3.2 Filtros Wireshark para FTP

Aplica estos filtros de visualización para analizar la sesión FTP:

**Filtro 1 — Canal de control FTP (comandos y credenciales):**

```
ftp
```

**Filtro 2 — Canal de datos FTP (contenido de ficheros transferidos):**

```
ftp-data
```

**Filtro 3 — Solo los comandos FTP enviados por el cliente:**

```
ftp.request.command
```

**Filtro 4 — Solo las respuestas del servidor:**

```
ftp.response.code
```

## 3.3 Identificar la secuencia de comandos FTP

Con el filtro ftp aplicado, identifica en los paquetes la siguiente secuencia de comandos y anota el número de paquete donde aparece cada uno:

| Comando / Respuesta FTP | Descripción | Nº paquete Wireshark |
|---|---|---|
| USER anonymous | Envío del nombre de usuario | _____ |
| PASS lab03@test.com | Envío de la contraseña (en texto claro) | _____ |
| 230 Login successful | Autenticación aceptada por el servidor | _____ |
| USER msfadmin | Segundo login con credenciales reales | _____ |
| PASS msfadmin | Contraseña real en texto claro | _____ |

| | | |
|---|---|---|
| LIST | Listado del directorio | _____ |
| PASV / PORT | Negociación del canal de datos | _____ |
| RETR <fichero> | Transferencia de fichero (si aplica) | _____ |

## 3.4 Reconstruir el canal de datos con Follow TCP Stream

Si se transfirió algún fichero, su contenido puede reconstruirse:

23. Filtra por ftp-data en Wireshark.
24. Haz clic derecho en un paquete de datos → Follow → TCP Stream.
25. El contenido del fichero transferido aparecerá en la ventana. Guárdalo como evidencia.

> ✓ **TIP:** Si el directorio FTP de Metasploitable 2 está vacío, crea un fichero de prueba primero desde la sesión SSH: ssh msfadmin@<IP_META> 'echo "dato_sensible_test" > /home/ftp/test.txt' y luego descárgalo por FTP. Esto simula una exfiltración de datos.

# TAREA 4 — Análisis de HTTP y SMB: más protocolos inseguros (40 min)

## 4.1 Captura de tráfico HTTP — Metasploitable 2 web

Metasploitable 2 tiene varios servicios web en el puerto 80 (puerto 8180 para Tomcat). El protocolo HTTP transmite credenciales de formularios en texto claro cuando no usa HTTPS.

26. Inicia captura con filtro BPF: host <IP_META> and port 80
27. Desde el navegador de Kali, accede a: http://<IP_META>/dvwa/
28. Accede también a: http://<IP_META>/mutillidae/ y http://<IP_META>/tikiwiki/
29. En alguna de las aplicaciones, intenta hacer login con credenciales por defecto (admin/admin, admin/password).
30. Detén la captura y guarda como: ~/lab03/captura_http.pcap

```
sha256sum ~/lab03/captura_http.pcap | tee ~/lab03/captura_http.pcap.sha256
```

## 4.2 Filtros Wireshark para HTTP

**Filtro 1 — Ver todas las peticiones HTTP:**

```
http.request
```

**Filtro 2 — Ver solo peticiones POST (envío de formularios con credenciales):**

```
http.request.method == "POST"
```

**Filtro 3 — Buscar cadenas de texto específicas en el contenido HTTP:**

```
http contains "password"
http contains "username"
```

**Filtro 4 — Ver respuestas del servidor con su código de estado:**

```
http.response.code == 200
http.response.code == 302
```

## 4.3 Extraer credenciales HTTP con tshark

Para un análisis más rápido, tshark puede extraer directamente los campos POST de los formularios de login:

```
tshark -r ~/lab03/captura_http.pcap -Y 'http.request.method == POST' \
  -T fields -e http.host -e http.request.uri -e http.file_data 2>/dev/null
```

Anota los resultados encontrados:

| Aplicación web | URI del POST | Credenciales capturadas | Protocolo seguro disponible |
|---|---|---|---|
| DVWA | _____ | _____ | HTTPS (no activo) |
| Mutillidae | _____ | _____ | HTTPS (no activo) |
| Tikiwiki | _____ | _____ | HTTPS (no activo) |
| Tomcat Manager | _____ | _____ | HTTPS (no activo) |

## 4.4 Captura de tráfico SMB — enumeración y autenticación

SMB (Server Message Block) es el protocolo de compartición de recursos de Windows/Samba. Las versiones antiguas como SMBv1 en Metasploitable 2 no cifran la autenticación.

31. Inicia captura con filtro BPF: host <IP_META> and port 445
32. Desde terminal, enumera los recursos compartidos:

```
smbclient -L //<IP_META>/ -N
smbclient -L //<IP_META>/ -U msfadmin%msfadmin
```

33. Detén la captura y guarda como: ~/lab03/captura_smb.pcap

```
sha256sum ~/lab03/captura_smb.pcap | tee ~/lab03/captura_smb.pcap.sha256
```

## 4.5 Filtros Wireshark para SMB

```
smb
smb2
smb.cmd == 0x73
```

El comando 0x73 es el Session Setup (autenticación). Analiza qué versión de SMB usa Metasploitable 2 y si el hash de contraseña viaja en la negociación de autenticación.

Anota la versión SMB detectada: _____ y el tipo de autenticación observado: _____

# TAREA 5 — Análisis de tráfico ARP e ICMP (30 min)

ARP (Address Resolution Protocol) opera en la capa 2 y es fundamental para el funcionamiento de la red. Su ausencia de autenticación lo hace susceptible a ataques de suplantación (ARP spoofing / ARP poisoning), una técnica clave en ataques de Man-in-the-Middle.

## 5.1 Captura de tráfico ARP

34. Inicia captura nueva con filtro BPF: arp
35. Genera tráfico ARP desde Kali:

```
# Forzar resolución ARP hacia Metasploitable 2
arping -c 5 -I <IFACE> <IP_META>

# Ver la tabla ARP actual de Kali
arp -n
ip neigh show
```

36. Detén la captura y guarda como: ~/lab03/captura_arp.pcap

```
sha256sum ~/lab03/captura_arp.pcap | tee ~/lab03/captura_arp.pcap.sha256
```

## 5.2 Filtros Wireshark para ARP

**Filtro 1 — Ver todo el tráfico ARP:**

```
arp
```

**Filtro 2 — Ver solo ARP Request (quién pregunta):**

```
arp.opcode == 1
```

**Filtro 3 — Ver solo ARP Reply (quién responde):**

```
arp.opcode == 2
```

**Filtro 4 — Detectar posible ARP spoofing (múltiples MACs para la misma IP):**

```
arp.duplicate-address-detected
```

## 5.3 Entender la estructura de un paquete ARP

En la captura ARP, selecciona un paquete ARP Request y despliega el árbol de protocolos en el panel inferior de Wireshark. Completa la siguiente tabla con los valores observados:

| Campo ARP | Descripción | Valor observado en la captura |
|---|---|---|
| Hardware type | Tipo de red (1 = Ethernet) | _____ |
| Protocol type | Protocolo de red (0x0800 = IPv4) | _____ |
| Sender MAC address | MAC del emisor del ARP Request | _____ |
| Sender IP address | IP del emisor | _____ |
| Target MAC address | 00:00:00:00:00:00 en Request (desconocida) | _____ |
| Target IP address | IP que se está buscando | _____ |

## 5.4 Análisis de ICMP — tráfico de diagnóstico

El tráfico ICMP (ping) también puede revelar información sobre la red. Analiza la captura general captura_general.pcap:

```
icmp
```

Identifica los siguientes elementos en los paquetes ICMP:

- TTL (Time To Live) de los paquetes de respuesta desde Metasploitable 2. El TTL inicial del sistema operativo puede estimarse: Linux suele empezar en 64, Windows en 128.
- Tamaño del payload ICMP. Nmap usa tamaños específicos según el tipo de sonda.
- Identificar si hay respuestas ICMP tipo 3 (Destination Unreachable) que revelen servicios filtrados.

| Parámetro ICMP | Valor observado | Inferencia |
|---|---|---|
| TTL de la respuesta de Metasploitable 2 | _____ | SO estimado: _____ |
| Tamaño de payload ICMP Echo Request | _____ | Origen: Ping manual / Nmap |
| ICMP tipo 3 detectado (Dest. Unreachable) | Sí / No | Servicios filtrados: _____ |

## TAREA 6 — Análisis con tshark: automatización y estadísticas (25 min)

tshark es la versión en línea de comandos de Wireshark. Permite automatizar análisis repetitivos y generar estadísticas útiles para informes de auditoría.

### 6.1 Estadísticas generales de la captura

```
# Resumen de protocolos presentes en la captura general
tshark -r ~/lab03/captura_general.pcap -q -z io,phs 2>/dev/null

# Top 10 conversaciones TCP por volumen de datos
tshark -r ~/lab03/captura_general.pcap -q -z conv,tcp 2>/dev/null | head -15

# Estadísticas por protocolo
tshark -r ~/lab03/captura_general.pcap -q -z ptype,tree 2>/dev/null
```

### 6.2 Extracción de artefactos específicos

```
# Extraer todos los hosts HTTP contactados
tshark -r ~/lab03/captura_http.pcap -Y http.request -T fields -e http.host -e
http.request.uri 2>/dev/null | sort -u

# Extraer User-Agents HTTP (identifican el navegador/herramienta)
tshark -r ~/lab03/captura_http.pcap -Y http.user_agent -T fields -e http.user_agent
2>/dev/null | sort -u

# Buscar texto sensible en todas las capturas
tshark -r ~/lab03/captura_ftp.pcap -Y 'ftp' -T fields -e ftp.request.command -e
ftp.request.arg 2>/dev/null

# Extraer IPs únicas que han comunicado con Metasploitable 2
tshark -r ~/lab03/captura_general.pcap -T fields -e ip.src -e ip.dst 2>/dev/null |
tr '\t' '\n' | sort -u
```

### 6.3 Generar informe de estadísticas para el entregable

```
# Generar resumen completo de todas las capturas
for pcap in ~/lab03/*.pcap; do
  echo "=== $pcap ==="
  tshark -r $pcap -q -z io,phs 2>/dev/null | grep -v '^$'
done > ~/lab03/estadisticas_capturas.txt

cat ~/lab03/estadisticas_capturas.txt
```

## TAREA 7 — Documentación de hallazgos de protocolo (30 min)

Documenta los hallazgos de protocolo con la siguiente estructura estándar. Se incluyen dos hallazgos completos como modelo; el alumno debe completar los restantes a partir de sus capturas.

| **P-02 FTP (puerto 21) — Riesgo ALTO — CWE-319 / CWE-425** | |
|---|---|
| **Descripción del riesgo** | FTP transmite el canal de control (credenciales y comandos) y el canal de datos (contenido de ficheros) en texto claro. El acceso anónimo habilitado permite a cualquier usuario de la red descargar ficheros del servidor sin autenticación. |
| **Filtro Wireshark** | ftp / ftp-data / ftp.request.command / Follow → TCP Stream |
| **Qué buscar / evidencia** | Credenciales FTP (usuario y contraseña) en paquetes del canal de control. Contenido de ficheros transferidos reconstruible desde el canal de datos. Comandos LIST, RETR, STOR visibles en texto claro. |
| **Control ENS / ISO 27001** | ENS: mp.com.2 (Cifrado de las comunicaciones). mp.com.3 (Autenticidad). ISO 27001:2022 A.8.24 (Criptografía). MAGERIT: Amenaza [A.5] dimensión C, [A.11] Acceso no autorizado. |
| **Recomendación** | Deshabilitar el servicio FTP. Migrar a SFTP (subsistema SSH, cifrado de extremo a extremo) o FTPS (FTP sobre TLS). Deshabilitar el acceso anónimo. Si FTP es imprescindible, restringir mediante reglas de firewall a IPs autorizadas. |

| **P-03 HTTP (puerto 80) — Riesgo MEDIO — CWE-319 / CWE-311** | |
|---|---|
| **Descripción del riesgo** | HTTP transmite el contenido de formularios web, incluyendo credenciales de login, en texto claro. Las aplicaciones web de Metasploitable 2 (DVWA, Mutillidae, Tikiwiki) usan HTTP sin cifrado. |
| **Filtro Wireshark** | http.request.method == "POST" / http contains "password" / Follow → HTTP Stream |
| **Qué buscar / evidencia** | Credenciales de formularios de login en paquetes POST. Campo http.file_data contiene los parámetros username= y password= en texto claro. Cookies de sesión visibles y reutilizables. |
| **Control ENS / ISO 27001** | ENS: mp.com.2 (Cifrado obligatorio para comunicaciones con datos personales). ISO 27001:2022 A.8.24, A.8.9 (Gestión de la configuración). MAGERIT: Amenaza [A.5] dimensión C. |
| **Recomendación** | Implementar HTTPS (TLS 1.2 mínimo, TLS 1.3 recomendado) para todas las aplicaciones web. Redirigir automáticamente HTTP → HTTPS. Activar el flag Secure y HttpOnly en las cookies de sesión. Implementar HSTS (HTTP Strict Transport Security). |

Hallazgos P-04 y P-05 — A completar por el alumno con sus capturas de SMB y ARP:

| Campo | P-04 SMB (completar) | P-05 ARP (completar) |
|---|---|---|
| Protocolo / Puerto | SMB / 445 | ARP / N/A (capa 2) |
| Riesgo CVSS / CWE | _____ | _____ |
| Descripción del riesgo | _____ | _____ |
| Filtro Wireshark usado | _____ | _____ |
| Evidencia obtenida | _____ | _____ |
| Control ENS / ISO 27001 | _____ | _____ |
| Recomendación | _____ | _____ |

# 5. ENTREGABLE — INFORME DE ANÁLISIS DE PROTOCOLOS

## 5.1 Estructura del informe

- 1. Portada: datos del alumno, fecha, entorno controlado, interfaces y máquinas utilizadas.
- 2. Tabla de capturas: listado de todos los ficheros .pcap con sus hashes SHA-256 y fechas (tabla de la Tarea 1.4).
- 3. Resumen ejecutivo: protocolos inseguros identificados, controles ENS incumplidos, recomendación principal.
- 4. Hallazgos de protocolo: fichas P-01 a P-05 completadas con evidencias y referencias normativas.
- 5. Análisis de sesiones: capturas de pantalla de Follow TCP Stream para Telnet, FTP y HTTP con credenciales visibles.
- 6. Estadísticas de red: salida del comando tshark -z io,phs y tabla de conversaciones.
- 7. Tabla de controles ENS incumplidos: mapping hallazgo → control ENS → recomendación.
- 8. Conclusiones: valoración del nivel de seguridad de las comunicaciones según ENS (mp.com.2, mp.com.3).
- 9. Anexos: todos los ficheros .pcap con sus hashes, fichero estadisticas_capturas.txt.

## 5.2 Tabla de controles ENS — resumen de incumplimientos

| Control ENS | Descripción | Hallazgo que lo incumple | Protocolo afectado | Prioridad |
|---|---|---|---|---|
| mp.com.2 | Cifrado de las comunicaciones | P-01, P-02, P-03 | Telnet, FTP, HTTP | ALTA |
| mp.com.3 | Autenticidad y confidencialidad | P-01, P-02 | Telnet, FTP | ALTA |
| op.mon.1 | Detección de intrusiones | Ausencia de IDS/IPS | Todos | MEDIA |
| mp.com.1 | Perímetro seguro | P-04 SMB expuesto | SMB/445 | ALTA |
| op.acc.4 | Control de acceso a red | P-05 ARP sin control | ARP/Capa 2 | MEDIA |

## 5.3 Ficheros a entregar

```
zip LAB03_[apellido]_[nombre].zip ~/lab03/
```

| Fichero | Contenido |
|---|---|
| captura_general.pcap | Captura general de tráfico Kali-Metasploitable 2 |
| captura_telnet.pcap | Sesión Telnet completa con credenciales |
| captura_ftp.pcap | Sesión FTP con canal de control y datos |
| captura_http.pcap | Tráfico HTTP con formularios de login |
| captura_arp.pcap | Tráfico ARP de la red |
| captura_smb.pcap | Tráfico SMB de enumeración |
| *.pcap.sha256 | Hashes SHA-256 de cada fichero .pcap |
| sesion_telnet_completa.txt | Exportación de Follow TCP Stream — Telnet |
| estadisticas_capturas.txt | Salida de tshark -z io,phs para todas las capturas |
| informe_lab03.pdf | Informe de análisis de protocolos completo |

# 6. PREGUNTAS DE REFLEXIÓN

- El ENS (mp.com.2) exige cifrado de las comunicaciones en sistemas de categoría MEDIA y ALTA. Has capturado credenciales de Telnet y FTP en texto claro. ¿Qué medidas técnicas concretas debería implementar el administrador del sistema para cumplir este control? ¿Cuál sería el plazo de corrección según el ENS?
- Wireshark tiene dos tipos de filtros: filtros de captura (BPF) y filtros de visualización. Explica la diferencia técnica entre ambos y en qué escenarios de auditoría usarías cada uno. ¿Por qué es importante para la cadena de custodia forense aplicar filtros BPF en lugar de filtros de visualización cuando el volumen de tráfico es alto?
- Has calculado el hash SHA-256 de cada fichero .pcap. ¿Para qué sirve este hash en el contexto de una auditoría forense? ¿Qué valor probatorio tendría una captura .pcap sin hash verificado en un procedimiento disciplinario o judicial según la legislación española?
- El protocolo ARP no tiene mecanismo de autenticación. Explica cómo se produciría un ataque ARP spoofing y qué evidencia dejaría en una captura Wireshark. ¿Qué control ENS / ISO 27001 mitigaría este riesgo y cómo se implementaría técnicamente en una red conmutada?
- Compara el nivel de riesgo de capturar credenciales HTTP frente a credenciales Telnet desde el punto de vista del RGPD art. 32 y MAGERIT v3. ¿Cambiaría tu evaluación si las credenciales HTTP dieran acceso a una base de datos con datos personales de clientes?

# 7. RÚBRICA DE EVALUACIÓN

| Criterio | Insuficiente (0–4) | Suficiente (5–7) | Excelente (8–10) |
|---|---|---|---|
| Uso de Wireshark y filtros (25%) | No genera capturas o usa filtros incorrectos | Capturas generadas y filtros básicos aplicados | Filtros precisos, uso de Follow Stream, exportación correcta de evidencias |
| Identificación de protocolos inseguros (30%) | No identifica protocolos de riesgo | Identifica al menos Telnet y FTP en claro | Identifica todos los protocolos inseguros con evidencia de credenciales capturadas |
| Análisis forense de red (25%) | Sin análisis o conclusiones vacías | Describe el tráfico observado | Reconstruye sesiones completas y extrae artefactos (credenciales, comandos) |
| Marco normativo (20%) | No referencia normativa | Menciona ENS o ISO en algún hallazgo | Cada hallazgo vinculado a control ENS (mp.com.2/3) e ISO 27001 A.8.20/A.8.24 |

Nota final: media ponderada de los cuatro criterios. Nota mínima de 5 en cada criterio para superar el laboratorio.

ℹ Las capturas .pcap de este laboratorio, especialmente captura_telnet.pcap, se reutilizarán en el LAB-07 (Análisis de riesgos MAGERIT) como evidencias del análisis de amenazas de interceptación [A.5]. Consérvalo.

# 8. REFERENCIAS

## Normativa


- Real Decreto 311/2022 — ENS. Medidas mp.com.2 (Cifrado), mp.com.3 (Autenticidad y confidencialidad), op.mon.1 (Detección de intrusiones). BOE núm. 106, 2022.
- ISO/IEC 27001:2022. Controles A.8.20 (Seguridad de redes), A.8.21 (Servicios de red), A.8.24 (Criptografía).
- RGPD — Reglamento (UE) 2016/679. Art. 5.1.f (Integridad y confidencialidad), art. 32 (Seguridad del tratamiento).
- CCN-CERT. MAGERIT v3. Libro II — Catálogo de amenazas [A.5], [A.9], [A.10], [A.11], [E.9]. Madrid: MINHAP, 2012.
- Ley de Enjuiciamiento Criminal, arts. 326-334 — Regulación de la prueba digital en España.
- CCN-STIC 817 — Gestión de ciberincidentes. Sección 4: Evidencias digitales y cadena de custodia.


## Técnicas


- Combs, G. et al. Wireshark User's Guide. https://www.wireshark.org/docs/wsug_html_chunked/
- Wireshark Foundation. Wireshark Display Filter Reference. https://www.wireshark.org/docs/dfref/
- SANS Institute. Wireshark Cheat Sheet. https://www.sans.org/security-resources/
- IETF RFC 826 — An Ethernet Address Resolution Protocol. D. Plummer, 1982.
- MITRE. CWE-319: Cleartext Transmission of Sensitive Information. https://cwe.mitre.org/data/definitions/319.html
- NIST SP 800-86 — Guide to Integrating Forensic Techniques into Incident Response. 2006.